

This document, titled "**Data Protection Impact Assessment (DPIA) Guideline**", has been prepared in accordance with the personal data protection law number (24) of 2023, issued on September 17, 2023, and published in the official gazette (5881).

This document serves as guideline only and does not constitute a legal document or a legal advice. Hereby, the concerned party is not obligated to adhere to the provisions outlined herein.

This manual is reviewed by the Personal Data Protection Directorate and updated as needed or in accordance with any amendments to the law, regulations, and instructions issued pursuant thereto.

| Privacy Policy Guideline |                                                                                                                                                                                                                                              |
|--------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Purpose                  | To guide the concerned entities on how to prepare a Data Protection Impact Assessment (DPIA) in accordance with the provisions of the Personal Data Protection Law No. (24) Of 2023 and based on best practices and international standards. |
| Scope                    | These guidelines target all entities concerned with the implementation of the Personal Data Protection Law No. (24) Of 2023, in addition to entities involved in the processing of personal data.                                            |

**The following words and phrases, wherever mentioned in this Guideline, shall have the meanings assigned to them below, unless the context indicates otherwise:**

- **Data Protection Impact Assessment:** The process of identifying and assessing potential risks resulting from data processing, in order to determine whether there are any negative impacts that could cause serious harm to the data subject. The purpose of conducting this assessment is to ensure compliance with the provisions of the personal data protection law and the regulations and instructions issued pursuant to it, to verify the lawfulness of the data processing activities, and to ensure that appropriate security, technical, and organizational measures are in place to mitigate or reduce risks.
- **Serious Harm:** Any material or non-material damage that may lead to discrimination, identity theft, fraud, financial loss, damage to reputation, violation of the confidentiality and integrity of personal data, or any social or economic impact that may affect the data subjects' ability to exercise their rights and freedoms.
- **Security measures:** A set of procedures taken to ensure the security and integrity of data base and systems that process data.
- **Technical measures:** A set of procedures taken to secure data bases, and the systems that process them against the risks of their use or against the unauthorized or illegal access.

- **Organizational measures:** A set of procedures taken to secure databases, organizational data bases, and the systems that process them by establishing regulations frameworks for institutions and organizations and the behavior of their employees.

Based On article (11), paragraph B/2 of the personal data protection law, which states that: “The Data Protection Officer shall assume the following duties and responsibilities: Ensure that a regular evaluation and examination for the data bases systems, the data processing systems and the systems for the protection of security and integrity and protection of the data is being conducted, document the results of such evaluation, issue the needed recommendations for the protection of data and follow up on the implementation of such recommendations.”.

Accordingly, this assessment is used to determine the risk level associated with the data being processed, the impact of any breach in data security and integrity, the nature and the likelihood of such breaches, in addition to their impact on the rights of the data subjects, in order to ensure that appropriate prevent measures are taken.

#### **When Data Protection Impact Assessment (DPIA) should be conducted:**

A Data Protection Impact Assessment (DPIA) is not mandatory for every processing activity; rather, it is considered mandatory in the cases stipulated in Article (6) of the Instructions on Technical and Organizational, Security Measures, which states:

To determine the level of risk of the data being processed and the impact of the level, type, and Likelihood of any breach of data security and integrity, as well as its impact on the rights of the Concerned persons, the official is obligated to prepare a "Data Protection Impact Assessment (DPIA)" during the processing procedures in any of the following two cases:

1. Processing sensitive personal data or transferring it outside the Kingdom.
2. Any other case for which the Council decides to require the official to prepare a "Data Protection Impact Assessment.

It should be noted that the **(DPIA)** must be conducted before initiating the data processing activity, especially when introducing new methods of processing or making a fundamental change to the existing processing activity. Any risk mitigation procedures should be incorporated into the project plan to ensure there implementation.

### The purpose of conducting a Data Protection Impact Assessment (DPIA):

1. To ensure compliance with the personal data protection law No. (24) Of 2023 and the regulations and instructions issued pursuant to it.
2. To verify the legality and legitimacy of the personal data processing.
3. To protect the rights of the data subjects and ensure that they are not exposed to any risks that may affect those rights, in accordance with article (4) of the personal data protection law No. (24) Of 2023.
4. To enable the entity to implement the principles of “privacy by design and privacy by default”.
5. To ensure that appropriate security, technical and organizational measures are taken during personal data processing.
6. To reduce and mitigate risks associated with personal data protection.
7. To enhance the principles of transparency and accountability in all personal data operations.

### Steps for conducting a data protection impact assessment (DPIA):

A Data Protection Impact Assessment (DPIA) shall be conducted prior to commencing the processing activity. The assessment includes the following:

|    |                                                      |                                                                                                                                                                                                                                                                                                                                                                                                                                    |
|----|------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 1. | <b>Controller Information</b>                        | <ul style="list-style-type: none"> <li>- Information about the data controller.</li> <li>- Information about Data protection officer.</li> </ul>                                                                                                                                                                                                                                                                                   |
| 2. | <b>Identifying the need for the DPIA</b>             | <ul style="list-style-type: none"> <li>- Clarifying the need and necessity to conduct this assessment.</li> <li>- Explanation of the types of processing to be used in achieving the intended purpose</li> </ul>                                                                                                                                                                                                                   |
| 3. | <b>Description of the processing and its purpose</b> | <ul style="list-style-type: none"> <li>- Clarifying the nature of the processing.</li> <li>- Clarifying the nature of the processing.</li> <li>- Providing a clear description of the processing context.</li> <li>- Describing the purposes and objectives of the processing.</li> <li>- Clarifying how data is collected, stored, and deleted.</li> <li>- Providing a clear description of the data transfer process.</li> </ul> |
| 4. | <b>Consultations</b>                                 | <ul style="list-style-type: none"> <li>- Clarifying how and when the opinions of information security experts will be sought.</li> <li>- Identifying the individuals who will be involved in the consultation process.</li> </ul>                                                                                                                                                                                                  |

|    |                                                                                                            |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
|----|------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|    |                                                                                                            | <ul style="list-style-type: none"> <li>- Clarifying whether consultation will be sought from internal data processors within the organization.</li> </ul>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
| 5. | <b>Description of the procedures for complying with the provisions of the Personal Data Protection Law</b> | <ul style="list-style-type: none"> <li>- Clarifying the legal basis for the processing activity.</li> <li>- Whether the processing achieves the purpose for which the data was collected.</li> <li>- Whether there are alternative ways to achieve the same purpose.</li> <li>- How conflicts of duties and roles will be prevented.</li> <li>- How the principles of data quality and data minimization will be upheld.</li> <li>- The data retention period.</li> <li>- The information that will be provided to the data subjects.</li> <li>- How data subjects will be enabled to exercise their rights in accordance with the provisions of the Personal Data Protection Law.</li> <li>- What measures have been taken to ensure that data processors comply with the Personal Data Protection law.</li> <li>- How data transfers outside the Kingdom are protected.</li> </ul> |
| 6. | <b>Identifying and assessing risks</b>                                                                     | <ul style="list-style-type: none"> <li>- Assessing the risks and clarifying their impact on the data subject.</li> <li>- Clarifying the source of the risk, its nature, and its likelihood, including.</li> <li>- The likelihood of the risk occurring (low / possible / likely).</li> <li>- The severity and level of the risk (minor / significant / severe).</li> <li>- The outcome of the risk (low / medium / high).</li> </ul>                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| 7. | <b>Measures to mitigate and reduce risks</b>                                                               | <p>Clarifying the security, technical, and organizational measures taken to mitigate and reduce the risks, as identified in Article (6) of this guidance document. This includes:</p> <ul style="list-style-type: none"> <li>○ A description of the nature of the risk.</li> <li>○ The options chosen to mitigate and reduce the risk.</li> </ul>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |

|           |                                          |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
|-----------|------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|           |                                          | <ul style="list-style-type: none"> <li>○ The impact of the chosen options on the risk (eliminated – reduced – accepted).</li> <li>○ The residual risks (low / medium / high).</li> </ul>                                                                                                                                                                                                                                                                                                                                                                                                              |
| <b>8.</b> | <b>Documentation of the DPIA process</b> | <p>The DPIA process must be documented to include all the points mentioned above. In cases where there is no need or necessity to conduct this assessment, this should be documented and clarified. Additionally, the following should be included:</p> <ul style="list-style-type: none"> <li>○ The recommendation of the controller.</li> <li>○ Comments and feedback from stakeholders.</li> <li>○ Approvals granted for the measures taken to mitigate and reduce risks, in order to ensure data protection.</li> <li>○ The person assigned to review and follow up on the assessment.</li> </ul> |
| <b>9.</b> | <b>Ongoing review and evaluation</b>     | <ul style="list-style-type: none"> <li>- The DPIA must be regularly reviewed and updated, along with continuous performance monitoring of the assessment process.</li> <li>- A reassessment may be required if there are any changes in the purpose or scope of data processing</li> </ul>                                                                                                                                                                                                                                                                                                            |

**References:**

To refer to the Security, Technical, and Organizational Measures Instructions for the year 2025, [please click](#)

| Version no. | Date | Prepared By | Reviewed By | Approved By |
|-------------|------|-------------|-------------|-------------|
| 1           |      |             |             |             |
|             |      |             |             |             |
|             |      |             |             |             |
|             |      |             |             |             |
|             |      |             |             |             |

This document has been prepared in accordance with international **ISO standards (ISO 9001:2015 Quality Management Systems)**.